

depSNORT

Dependency supply-chain scan report

dev - static, zero-execution analysis

INCOMPLETE - 1 finding(s), nothing block-class, but degraded data source(s): osv. Exit 0.

SCOPE

Root: pkg:pypi/pinned-scan-dir@0.0.0
Graph: 32 nodes (21 packages, 11 install hooks, 0 referenced artifacts, 0 sinks), 31 edges
Findings: 0 block, 0 gate-eligible, 1 advisory (1 total)

RESOLUTION COVERAGE

Flat resolution (pypi): this lockfile format records no inter-package relationships, so those packages resolve at depth 1 by construction, not by fact. Transitive structure is unavailable for them and the depth column below should not be read as a dependency tree.
Data source(s) degraded (osv): advisories or release history were unavailable for some coordinates, so vulnerability and temporal checks are a lower bound over them.

DATA SOURCE COVERAGE

osv online - queried 20, cache 0, network 0, advisories 0, gaps 20
Coverage is incomplete: 20 coordinate(s) returned no data. Findings below are a lower bound.
Error: osv: querybatch: Post "https://api.osv.dev/v1/querybatch": Forbidden
npm-registry online - queried 0, cache 0, network 0, advisories 0, gaps 0
pypi-registry online - queried 20, cache 20, network 0, advisories 0, gaps 0
rubygems-registry online - queried 0, cache 0, network 0, advisories 0, gaps 0
cargo-registry online - queried 0, cache 0, network 0, advisories 0, gaps 0
composer-registry online - queried 0, cache 0, network 0, advisories 0, gaps 0
nuget-registry online - queried 0, cache 0, network 0, advisories 0, gaps 0

FINDINGS

By check: VC-004 x1

ADVISORY

VC-004 pypi/pyasn1@0.6.4
0.6.4 published after 492d of dormancy
severity medium - confidence 0.40 - recency 0.198 - score 0.040
Evidence: dormancy gap: 0.6.1 -> 0.6.2 (492d, 2024-09-10 -> 2026-01-16)
Remediation: verify the publishing account and confirm the release corresponds to reviewed source changes

PACKAGE RISK

1 package(s) carry a risk state and are listed below. A further 20 resolved package(s) are clean and are not listed.

RISK	PACKAGE	VERSION	DEPTH
WARNED	pyasn1	0.6.4	1

depSNORT performs static analysis only: it parses manifests and lockfiles and never runs a package manager or executes a lifecycle hook. It detects capability and indirection, not payload semantics. Advisory findings never affect the exit code; gate-eligible findings do so only when the run opts in; block findings always fail.
Report output is deterministic (no embedded timestamp).